

Woche 1 - Blocker Checkliste

CargoBit Payment System - Produktionsreife Implementierung

1. Übersicht

Diese Checkliste enthält alle kritischen Aufgaben für Woche 1. Jede Aufgabe ist einem Tag zugeordnet und enthält konkrete Schritte, Fallstricke und Akzeptanzkriterien. Die Reihenfolge ist optimiert für minimale Abhängigkeiten und maximale Parallelisierung.

2. Tagliche Aufgaben

Tag 1: PostgreSQL Migration

Aufgabe	Status	Verantwortlich	Notizen
Postgres Instanz erstellen (Neon/Supabase)	[]		Freies Tier ausreichend
DATABASE_URL in .env setzen	[]		postgresql://...
Prisma Schema prüfen	[]		Enum-Konflikte beheben
Migration mit prisma migrate diff erzeugen	[]		SQLite -> Postgres
Migration auf Postgres anwenden	[]		psql -f migrations/init.sql
Prisma Client neu generieren	[]		npx prisma generate
Datenmigration testen	[]		Null-Werte bereinigen
Rollback-Plan dokumentieren	[]		SQLite Backup behalten

Wichtige Fallstricke:

- SQLite erlaubt Null-Werte, die Postgres nicht erlaubt - vorher bereinigen
- Enum-Typen müssen in Postgres explizit erstellt werden
- Unique Constraints können bei Migration fehlschlagen - Duplikate prüfen
- FOREIGN KEY Constraints werden strenger geprüft - Referenzen validieren

Tag 2: Redis Rate Limiting

Aufgabe	Status	Verantwortlich	Notizen
Redis Instanz starten (Docker/Cloud)	[]		Upstash empfohlen
REDIS_URL in .env setzen	[]		redis://... oder rediss://
ioredis Package installieren	[]		npm install ioredis
Token Bucket implementieren	[]		Siehe Code-Vorlage

Rate Limiter Middleware erstellen	[]		Pro Endpoint konfigurierbar
Admin-Endpoints hart limitieren	[]		10 req/min
Rate Limit Headers hinzufügen	[]		X-RateLimit-*
Integration Tests schreiben	[]		Concurrency testen

Wichtige Fallstricke:

- Redis TTL muss gesetzt werden - sonst Speicherueberlauf
- Key-Prefix pro Service verwenden - Kollisionen vermeiden
- Bei Redis-Ausfall: Circuit Breaker mit Fallback-Strategy
- Sliding Window statt Fixed Window für glatte Begrenzung

Tag 3: Backups + PITR

Aufgabe	Status	Verantwortlich	Notizen
Postgres PITR aktivieren	[]		Neon: automatisch
Wal-G oder pgBackRest konfigurieren	[]		Self-hosted Option
Backup-Schedule definieren	[]		Täglich um 3:00 UTC
S3 Backup-Bucket erstellen	[]		Verschlüsselt
Backup-Skript schreiben	[]		pg_dump + s3 cp
Restore-Prozedur dokumentieren	[]		Schritt-für-Schritt
Restore testen (CRITICAL!)	[]		Ohne Test wertlos
Retention Policy festlegen	[]		30 Tage / 90 Tage

Wichtige Fallstricke:

- WAL Retention zu kurz - PITR nicht möglich
- Backups ohne Verschlüsselung - Datenschutzverletzung
- Kein Restore-Test - Backup ist wertlos bei echtem Vorfall
- Backup-Ziel in gleicher Region wie DB - Regionalausfall trifft beides

Tag 4: Stripe Webhook Validation

Aufgabe	Status	Verantwortlich	Notizen
STRIPE_WEBHOOK_SECRET setzen	[]		whsec_XXX
Raw Body Parser konfigurieren	[]		express.raw()
Signature Validation implementieren	[]		stripe.webhooks.constructEvent
Idempotency Key speichern	[]		Processed Events Tabelle
Event-Deduplication testen	[]		Gleiche Event-ID zweimal senden
Webhook-Endpoint absichern	[]		Nur von Stripe aufrufbar
Error-Handling implementieren	[]		5xx vs 4xx richtig setzen
Monitoring/Alerting einrichten	[]		Failed Webhooks

Wichtige Fallstricke:

- Body muss RAW sein - JSON.parse zerstört Signatur
- Signature MUSS immer validiert werden - keine Ausnahmen
- Idempotency Key ist Pflicht - Replay-Angriffe sonst möglich
- Webhook Timeout unter 5 Sekunden - Stripe wiederholt sonst

Tag 5: Audit Log Hardening

Aufgabe	Status	Verantwortlich	Notizen
Audit Log Tabelle erstellen	[]		Mit Hash-Spalte
Hash-Chain implementieren	[]		SHA256(prev + curr)
Write-Only Constraint setzen	[]		Kein UPDATE/DELETE
Audit Middleware erstellen	[]		Alle Aktionen loggen
S3 Export Job einrichten	[]		Täglich um 4:00 UTC
Integritätsprüfung schreiben	[]		Hash-Chain verifizieren
Retention Policy (90-180 Tage)	[]		Compliance-Anforderung
Zugriffskontrolle definieren	[]		Nur Compliance-Team

Wichtige Fallstricke:

- Kein UPDATE/DELETE erlauben - Trigger setzen
- Hash-Chain muss bei JEDEM Eintrag geprüft werden
- Logs müssen 90-180 Tage aufbewahrt werden (Compliance)
- S3 Export muss verschlüsselt sein

Tag 6-7: Testing & Deployment

Aufgabe	Status	Verantwortlich	Notizen
Alle Integration Tests grün	[]		100% Pass
Load Tests durchführen	[]		k6 oder Artillery
Staging Deploy	[]		Produktions-ähnlich
Smoke Tests auf Staging	[]		Kritische Pfade
Security Scan (OWASP Top 10)	[]		Automatisiert
Code Review abgeschlossen	[]		Min. 2 Reviewer
Production Deploy	[]		Blue-Green empfohlen
Post-Deploy Monitoring	[]		30 Min Beobachtung

3. Akzeptanzkriterien für Woche 1

Kriterium	Status	Beweis
PostgresMigration abgeschlossen	[]	Alle Tests grün
Redis Rate Limiting aktiv	[]	Load Test bestanden
Backups funktionieren	[]	Restore erfolgreich
Stripe Webhooks validiert	[]	Replay-Test bestanden
Audit Logs immutable	[]	Hash-Chain verifiziert
Staging Deploy erfolgreich	[]	Smoke Tests grün
Production Ready	[]	Go/No-Go Meeting